

HKS SECURITY & AI LAB · ASSIGNMENT 1

ISO/IEC 27001 SOC 2

One risk-based control library. Two assurance regimes.
Evidence collected by code instead of screenshotted by hand.

Ahmed Arebi · Abo Alqasem Elkorbow · Marwan Elamami

93

controls · 4 themes
one library

HOW WE APPROACHED THIS

We read the standards before the blogs

The three of us researched Assignment 1 independently, then challenged each other's drafts before merging into one report.

Primary sources first

Every definition below was located as literal text inside the official PDFs provided to us, rather than recalled from model output or blog summaries.

AI where it actually helps

We used AI to triage research and draft faster, then verified every load-bearing claim against source text. Claims we could not trace got marked rather than quietly kept.

We argued, then resolved

Our reports disagreed on real questions: control selection, overlap claims, SLA numbers. We resolved them on evidence and kept the reasoning visible.

WHERE WE LANDED

“Can this organisation be trusted with **other people’s risk?**”

Both frameworks are answers to that question. They differ in packaging more than philosophy. That is why our report builds one control library and maps it outward.

ISO/IEC 27001: certifiable standard

Clauses 4–10 define the auditable ISMS. Annex A holds 93 reference controls (37/8/14/34; we counted them in the PDF you gave us). Certification runs Stage 1 + Stage 2 on a 3-year cycle. It certifies the system in scope, never products.

SOC 2: attestation engagement

No certificate exists. A CPA firm issues an opinion under AT-C 105/205. Five TSC categories, Security mandatory. Type 1 tests design at a date; Type 2 tests operating effectiveness across an agreed period (3–12 months).

Both are risk-based: CC3 requires formal risk assessment. Our own first draft claimed otherwise; checking CC3 corrected us. If we ever need both: build the ISMS first, run SOC 2 on top of it.

Differences that **matter**, plus claims we reject

Dimension	ISO/IEC 27001	SOC 2
Output	Certificate, 3-year cycle with surveillance audits	Dated opinion; market expects an annual refresh
Governance machinery	Explicit: SoA, internal audit (9.2), management review (9.3)	Implied via criteria (CC3, CC4); nothing prescribed
Evidence bar	System conformity, sampled at audit	Type 2: complete populations across the whole period
Visibility	Public certificate; audit material private	Restricted-use report under NDA; SOC 3 is the public summary

We reject “80% overlap”

Unfalsifiable as stated. Controls overlap heavily; the evidence work does not, and the evidence work is where cost sits.

We reject fixed Type II periods

“Must be exactly 6 or 12 months” is convention, not rule. The period is agreed with the CPA firm.

Points of focus aren’t required

TSP 100 says so explicitly. Building a control per PoF is the expensive first-timer mistake we want to avoid.

ISMS: controls are the product. The ISMS is **the factory**.

- **What it is:** the repeatable system that decides which controls we need, assigns owners, measures performance, verifies operation, and improves the result. Not a software product, not a folder of policies.
- **Why it matters more than any single control:** anyone can install MFA. The factory is what determined MFA was right, assigned its owner, set its target, measured it six months later, audited that measurement, escalated the failure and closed the loop.
- **Where organisations actually fail:** clauses 9 and 10, the measurement, audit, review and corrective-action clauses. We found most major nonconformities land there, not on Annex A technology.
- **The loop:** context, planning, operation, evaluation, improvement, with incidents and metrics feeding back into context. That return path is the part everyone skips, and the part auditors probe hardest.

A control produces a record, or it isn't one

ISO/IEC 27002 defines it precisely: “a measure that modifies or maintains risk.” Note the modesty: modifies, not eliminates. We add one operational requirement of our own.

MFA is not a control. “All privileged access requires phishing-resistant MFA, enforced by IdP policy X, reviewed monthly by owner Y, evidenced by configuration export Z” is. The first is a purchase. The second is a claim someone can test.

- **Strong statements share six elements:** a named owner, specific action, defined population, frequency or trigger, mechanism, named record, plus a failure threshold. Miss one and the auditor writes the control up.
- **Design vs operating effectiveness** is the spine of SOC 2. A quarterly access review can be perfectly designed and still fail if nobody performed it in Q3 because the owner was on leave.
- **Automated controls change the economics.** They don't forget, but they can be changed, disabled or bypassed, which is why we treat change management and logging as load-bearing for everything else.

Evidence is where compliance is won or lost

- **In a Type 2 the opinion is formed on evidence.** Immaculate records beat mediocre-but-real security. Uncomfortable, but that is how assurance works.
- **Four kinds:** design (would it work?), implementation (does it exist?), operating (did it run, every time?), population (is our list complete?). Population is always the weakest link.
- **Audit-grade means:** attributable, timestamped, pulled from the system of record, demonstrably complete, reproducible, tamper-evident and retained. A screenshot offers maybe one of those seven properties.
- **GDPR Article 5(2)** makes “able to demonstrate compliance” documentation law, not good practice.
- **The IPE trap:** hand over “the list of all production changes” and the auditor must test whether your list is complete. Our fix throughout is reconciliation between independent sources: CloudTrail against merged PRs, HRIS against IdP, scanner coverage against inventory.

PART ONE · OUR FIVE CONTROLS

We picked on attack data, not on what documents easily

39%

of breaches involve
credential abuse

#1

initial-access vector:
vulnerability exploitation (31%)

48%

of breaches involve
ransomware

Three controls were unanimous among us before we compared notes: identity, vulnerability management, logging.

The fifth slot genuinely divided us. Ahmed argued encryption, Qasim argued backup, Marwan argued awareness.

We resolved it on this data: recovery limits damage when everything else has already failed, so backup and recovery took the slot. Encryption folded into it as data protection. Awareness stayed documented under considered-not-selected.

(Verizon 2026 DBIR reported figures; relied on directionally.)

HKS-AC-01 · Identity & access lifecycle

Stage	What we specify
Risk	Credential abuse appears in 39% of breaches and precedes half of ransomware events. Phishing captures passwords; leavers keep access; privilege creep accumulates. If identity fails, every other control is bypassable.
Control	Phishing-resistant MFA for all privileged human access; least privilege by role; short-lived federated credentials for machines; revocation triggered by HR events within 24 hours.
Implementation	One authoritative IdP with conditional access · FIDO2/WebAuthn keys or passkeys · joiner-mover-leaver processes that replace rather than add permissions · break-glass accounts separately monitored and tested after every use.
Evidence	Our strongest artefact is a daily HRIS ↔ IdP ↔ cloud reconciliation: no enabled account without an active HR record, no leaver still enabled. Plus access-review sign-offs, MFA exports, revocation latency logs.
Testing	Password-only privileged authentication must hard-fail. Expired access must fail. We sample leavers from HRIS and trace deactivation times against the 24-hour target.
Automation	Nightly job diffs IdP users against HR headcount and auto-tickets orphans; cloud policy checks MFA and key rotation; OIDC trust audits reject wildcard conditions; policy-as-code blocks over-broad grants at deploy.

FIDO's claim stayed precise in our report: phishing-resistant when correctly implemented, with public-key crypto bound to the legitimate origin.

HKS-VM-03 · Vulnerability & configuration management

Stage	What we specify
Risk	Exploitation of known vulnerabilities is now the #1 initial-access vector at 31% of breaches. Median remediation 43 days; only 26% of KEV entries fully remediated. The gap is operational, not technical.
Control	Inventory every asset; scan continuously; prioritise by exploitability and exposure (KEV membership, EPSS) rather than CVSS alone; remediate within risk-based SLAs; exceptions require an owner and an expiry date.
Implementation	Authenticated weekly scans of all hosts, daily for internet-facing · infrastructure version-controlled as IaC and scanned before deployment · runtime drift detected and reverted or formally accepted · SBOMs per release.
Evidence	Findings with first-observed timestamps; tickets linking finding → fix → verification rescan; SLA attainment per severity; exception register with expiry; scanner coverage reconciled against asset inventory.
Testing	We plant a deliberately vulnerable test image: it must be detected, ticketed, escalated. An out-of-band configuration change must be caught, attributed and reverted. A pentest validates what scanners miss.
Automation	API-sync findings into ticketing with SLA clocks from first detection; auto-close only on verified rescan; Checkov/OPA in CI blocks vulnerable configs before deployment; overdue findings escalate themselves.

For us coverage is a first-class metric. Ninety-eight percent remediated within SLA means little if 40% of the estate never reaches the scanner.

HKS-LM-04 · Logging, monitoring & incident response

Stage	What we specify
Risk	Breaches dwell undetected for weeks when nobody watches telemetry. Late detection multiplies impact through lateral movement, exfiltration and late-notification penalties. Attackers who can delete local logs erase their own trail.
Control	Security-relevant events collected with reliable timestamps and integrity protection; anomalies monitored and evaluated; incidents responded to through a defined program; recovery rehearsed.
Implementation	Centralised SIEM covering identity, cloud control plane, endpoint, application, backup logs · clock sync (A.8.17) · collection separated from analysis privileges · WORM storage where warranted · IR plan with severity matrix · tabletops twice yearly · GDPR 72-hour notification workflow.
Evidence	Log-source coverage matrix; ingestion-health dashboard; alert-to-triage trails with response times; IR plan versions; tabletop records; postmortems. We are honest about WORM: it prevents alteration but doesn't prove complete collection.
Testing	Monthly detection canaries verify the whole chain. Purple-team injections verify specific alerts fire and pages land. We attempt log deletion in test, and it must be denied and captured.
Automation	SOAR playbooks speed containment (auto-isolate endpoint, revoke sessions), gated behind strong authorisation, rollback paths and human escalation. Coverage and MTTD metrics export continuously.

Logging carries weight beyond detection. Without trustworthy logs we cannot prove any other control in this deck ever operated.

HKS-CM-02 · Secure change & CI/CD integrity

Stage	What we specify
Risk	Unreviewed change is self-inflicted breach: one misconfigured bucket exposes data instantly. Compromised build tooling turns the pipeline itself into the attack vector, and it is now the shortest route to production.
Control	Every production change passes an auditable lifecycle: authorisation, independent review, security gates, approval, controlled deployment, rollback capability. Build inputs/outputs carry provenance; emergency changes get documented retro-review within 48h.
Implementation	Protected main + mandatory peer review + CODEOWNERS on security-sensitive paths · stale approvals dismissed · SAST/SCA/secrets scanning in CI · dependency pinning · SBOM generation · artefact signing verified at deploy · environments separated, prod write-access restricted.
Evidence	PR history with reviewer identities; CI logs proving gates executed; deployment approvals; SBOMs linked to releases; emergency-change retro-reviews. Our strongest single artefact: reconcile CloudTrail deployments against merged approved PRs.
Testing	Negative tests in staging: we plant a secret, a vulnerable dependency, an unsigned artefact, a self-approved change; each gate must block it. Direct prod push must fail on branch protection.
Automation	The pipeline generates its own evidence: every commit yields immutable proof of review, tests and approval. Policy-as-code returns allow/deny before noncompliant infrastructure exists. Remediation PRs proposed to humans, never auto-merged.

The only control where a preventive gate touches every change at almost no marginal cost, and it is where GRC-as-Code pays off most visibly.

HKS-BR-06 · Backup, recovery & data protection

Stage	What we specify
Risk	Ransomware reached 48% of breaches. Encryption of data, destructive deletion, compromised backup credentials, prolonged outage. Backups that exist but were never restored are a hope, not a control. Unprotected copies also leak.
Control	Protected recoverable copies including at least one outside the production attack path; demonstrated restore within approved RTO/RPO; confidential data encrypted with key administration separated from key use.
Implementation	Encrypted backups · separate backup administration with its own MFA · immutable retention plus account/region separation and offline copies where justified · clean recovery environment · customer-managed keys with rotation and use restrictions.
Evidence	Job-success history; immutability configuration exports; key-rotation status; restore runbooks; measured RTO/RPO from exercises; corrective actions from failed tests tracked to closure.
Testing	Scheduled restores with representative data measure actual recovery time and data loss against objectives. Clean-room recovery. Attempt to modify backups during retention: must hold. Test credential isolation between backup admin and production.
Automation	Alert on failed jobs AND retention-configuration changes; generate recovery-evidence packages automatically; gate incident closure on evidence of successful restoration, not on a green backup dashboard.

Backups existing is not the same as being able to recover. The assurance question is whether we can restore trustworthy services from copies an attacker cannot destroy.

Reconciliation, coverage, **one library**

We reconcile, not sample

Sampling compliant PRs proves only that compliant changes were compliant.

CloudTrail deployments vs merged approved PRs proves the population is **complete**.

Same logic everywhere: HRIS vs IdP; scanner vs inventory.

Coverage is first-class for us

98% within-SLA means nothing if 40% of our estate is invisible to the scanner.

So we reconcile scanner coverage against asset inventory every cycle.

And log sources vs systems. And backup coverage vs critical data.

One library, mapped outward

Each control defined once: owner, statement, mappings, evidence, tests, exceptions.

Mappings stored as data: Annex A, TSC, CSF, CIS. New framework = new column.

The SoA gets generated from it, executing clause 6.1.3(c) automatically.

By GRC-as-Code we mean refusing to let paperwork drift from reality. Evidence gets collected once by code, hashed and immutable, then presented many times.

the Evidence Sufficiency Reviewer

All three of us proposed variants of this idea independently, before comparing notes. We read that convergence as a finding: implementing controls is affordable, continuously proving them is not.

1 · Deterministic checks first

Dates, hashes, record counts and control IDs get verified in code before any model runs. About half of real evidence defects die here at zero inference cost. We never ask a model a question a comparison operator can answer.

2 · Retrieval-grounded triage

The model reasons only over supplied control text and the artefact itself, never from memory. Verdicts come back as constrained JSON with exact quotations from the artefact.

3 · Asymmetric authority

A positive verdict changes nothing; only flags open a human review task. A hallucinated approval therefore has no path to acceptance, and prompt injection buys an attacker nothing.

We treat evidence as untrusted input, because commit messages and tickets can carry injection payloads. Every decision gets logged: model ID, prompt version, context hash, output, human disposition. An AI system inside an evidence framework must itself be auditable, so we aligned it with NIST AI RMF and mapped it onto ISO/IEC 42001.

How we would know the ESR works

Element	What we commit to
Labelled evaluation set	~200 artefacts, half deliberately defective with defects drawn from real audit findings, built BEFORE writing the prompt, so the prompt is not tuned to its own test
Primary metric	Recall on defective artefacts ≥ 0.95 ; missing a bad artefact costs an exception in Section IV of the report
Secondary metric	Precision ≥ 0.70 : below ~0.5 the queue becomes noise and analysts rubber-stamp. That floor is a human-factors threshold, not a technical one
Adversarial suite	Injection payloads planted in log lines, ticket bodies, commit messages → required result: zero behaviour change
Explicit non-metric	“Time saved” stays out of the metrics on purpose. Judging the tool on reduced review pushes incentives straight through the asymmetry guardrail
Pilot & exit	build, shadow, assist, then decide at week 13: keep, tune or stop, based on results. Saying up front that we might switch it off is what keeps the pilot honest

Where we disagreed · what we **won't claim**

- **Fifth control:** encryption (Ahmed) vs backup (Qasim) vs awareness (Marwan). Resolved toward recovery on DBIR data, with encryption folded in. Awareness stayed documented; losing the slot did not mean losing the argument.
- **"80% overlap" between the frameworks:** rejected as unfalsifiable. The controls overlap; the work does not.
- **Fixed SLA numbers** such as 72-hour patching or 24-hour revocation appear as design examples only. Each organisation sets its own values.
- **Kept genuinely open:** Object Lock compliance mode versus erasure rights pits evidential integrity against privacy law; the industry has not settled it and neither have we. Same for calling asset inventory "control zero."
- **Limitations we state plainly:** this is design rather than deployment, and building AC-01 and LM-04 in a sandbox account is our stated next step. DBIR figures are directional. Mappings stay illustrative until scoped.

CLOSING

What compliance actually asks of us

Decisions we can justify. Controls we can show running.
Weaknesses found and fixed before an auditor finds them.

Ahmed Arebi · Abo Alqasem Elkorbow · Marwan Elamami

Questions welcome; the hard ones especially.